

AdvocateAuroraHealth

Title: AAH Payment Card Industry - Data Security Standards		Document Number: 760
Document Type: ☐ Policy ☐ Procedure ☐ Guideline ☐ Other		Last Review/Revision Date: 06/24/2021
Content Applies to Patient Care: (Select all that apply) ☐ Adults ☐ Pediatrics (Under 18)	Content Applies to: (Select One) ☐ Clinical ☐ Administrative	Next Review Date: 06/24/2022
		Effective Date: 06/24/2021
Scope: ☐ AAH System ☐ ACH ☐ AAH IL Only ☐ AAH WI Only ☐ Site Only (Location Name): ☐ Department Only (Department Name):		

I. PURPOSE

The purpose of this Payment Card Industry-Data Security Standards (PCI-DSS) Policy is to establish requirements to ensure that Advocate Aurora (AAH) is compliant with PCI-DSS. The PCI-DSS requirements apply to all payment card network members, merchants, and service providers that store, process or transmit cardholder data. This policy provides a framework under which the AAH business processes, systems, applications, and facilities that process, store, transmit or handle Cardholder Data should operate. AAH management has committed to compliance with the PCI-DSS and to protect credit cardholder data utilized by AAH in the course and scope of its business.

II. SCOPE

This policy applies to Advocate Aurora, any entity or facility owned or controlled by Advocate Aurora, and any partnerships, affiliations, /hosting, or contractual arrangements where Advocate Aurora systems may be used to process and/or transmit credit card payments. The policy is applicable where Customer Cardholder Data is stored, processed, or transmitted through the Advocate Aurora environment and/or a third-party service provider environment contracted by Advocate Aurora. This Policy is applicable to all systems, people and processes which handle information residing in the Advocate Aurora Cardholder Data Environment (CDE) and to any systems, people and processes that handle cardholder information on the proprietary networks and systems of Advocate Aurora. The requirements apply to all methods of credit card processing, from manual to computerized.

Roles and Responsibilities related to this Policy are documented in Attachment A of this Policy.

This policy does not apply to payment card services provided by vendors or partners on their own behalf, except where they are connected to the Advocate Aurora network.

III. DEFINITIONS/ABBREVIATIONS

Payment Card Industry Data Security Standard (or “PCI DSS”): PCI DSS is a proprietary information security standard for organizations that accept branded credit cards (i.e., American Express, Discover, MasterCard, or Visa) for payment of services, goods or donations. PCI-DSS is updated periodically by the Payment Card Industry Security Standards Council (PCI-SSC).

Primary Account Number (PAN): 14 or 16-digit account number that is embossed on the face of a payment card and encoded in the card's magnetic strip

Cardholder Data (CHD): Includes Primary Account Number (PAN), Cardholder Name, Expiration Date and Service Code.

Cardholder Data Environment (CDE): The CDE includes any system components (i.e. network component, firewalls, servers, systems, applications, storage, etc.) that transmit, store or process Cardholder Data and any ancillary system components that directly access or reside within the same network as the CDE.

Card Verification Value (CVV): 3 or 4-digit number on the back of Visa, MasterCard, Discover, and on front of American Express payment cards. Also known as CSC (Card Security Code) or CVC (Card Verification Code).

Sensitive Authentication Data (SAD): Includes Full track data (magnetic-stripe or equivalent on a chip), Card Authentication Value 2(CAV2), Card Validation Code 2(CVC2), Card Verification Value 2(CVV2), Check ID (CID)

Merchant: Any department that collects credit card payments as revenue. Although merchants may receive payments in various forms (i.e. cash, check, credit card, etc.), this policy applies to those departments who receive at least some of their payments from credit card transactions.

Merchant ID (MID): A merchant identification code assigned by the bank and used to identify the owners of credit card transactions.

Payment Channel: An individual process or mechanism used by Advocate Aurora to accept customer credit card payments. Websites, standalone credit card terminals (dial-up or IP connected), and integrated Point-of-Sale solutions are all examples of different Payment Channels.

PCI Self-Assessment Questionnaire (SAQ): A tool created by the PCI-SSC intended to assist merchants and third-party service providers in evaluating their compliance with the PCI DSS and related requirements.

Qualified Security Assessor (QSA): Individuals or organizations certified by the PCI SSC to perform payment card industry compliance auditing and consulting. QSAs are authorized to issue Reports on Compliance.

Team Member: Employees of Advocate Aurora or any affiliated entity (including entities affiliated with Advocate Aurora by contract) and anyone who provides services on behalf of Advocate Aurora. All Team Members are expected to abide by Advocate Aurora policies and procedures.

IV. POLICY

1. Any department that needs to accept credit card payments through any method (i.e.: e-commerce, paper, Point-of-Sale (POS) terminal) must first request a unique Merchant ID and all card processing equipment from the Treasury Department. All processing equipment issued by the Treasury Department must be pre-approved by HIT Security and the PCI Steering Committee.
 - a. The Treasury Department shall notify HIT Security of any new equipment being deployed and HIT shall establish the appropriate secure connections with any websites, payment portals, or gateways through which credit card transactions will be conveyed.
 - b. Treasury Services is responsible for obtaining and maintaining a list of all Merchant Account ID's assigned to and used by Advocate Aurora.
2. Any new credit card processing system that is not pre-approved, or any change to an existing system, must be reviewed and approved by HIT Security and the PCI Steering Committee prior to implementation.
3. Every effort will be made to eliminate the storage, processing, or transmission of Cardholder Data by AAH-hosted systems through PCI scope reduction techniques.
 - a. CHD must never be stored in the AAH environment, and unencrypted CHD must never be processed or transmitted in the CDE.
 - b. The PCI DSS Steering Committee shall review and approve in writing any exceptions.
 - c. SAD must never be stored on any system within the CDE.
 - d. Unmasked PANs must never be sent via electronic messaging technologies (including but not limited to email, text, etc.).
4. Each department with a MID is responsible for documenting and maintaining PCI-DSS compliant processes and procedures necessary to support their business processes. Each department with a Merchant account shall notify the Treasury Department of any (1) requests for new equipment, (2) relocation of equipment, or (3) decommissioning of equipment.

5. CHD (credit card number CVV code, track data) is not to be stored, processed, or transmitted on any Advocate Aurora system in any form. This includes electronic and written credit card data, unless tokenized using AAH PCI approved solutions.
6. HIT is responsible for documenting and maintaining:
 - a. A PCI DSS Information Technology Standard with technical and operational requirements for the AAH HIT computerized environment that processes payment card data
 - b. A compliance framework addressing operational controls, HIT infrastructure and programs used to process credit card transactions
 - c. An ongoing work plan documenting the approach, steps and timeline to achieve and maintain certification of PCI-DSS compliance
 - d. Data Flow Diagrams that demonstrate the flow of PCI Data through each Payment Channel, and whether that PCI Data is tokenized, encrypted, or otherwise exposed to an AAH-hosted system
 - e. Architectural Context Diagrams that depict system integrations that exist within each Payment Channel, as well as the nature of those integrations (middleware, firewalls, network segmentation, etc.)
 - f. Selection of Qualified Security Assessors
 - g. Completion of PCI Self-Assessment Questionnaires and/or coordination of Attestation of Compliance (AOC)
 - h. Maintenance of accurate Credit Card Terminal inventory.
 - i. Engagement of annual Credit Card Terminal inspection.
7. The Treasury Department is responsible for all non-technical aspects of merchant card processing, including:
 - a. Selection of and contracting with merchant card processors
 - b. Management of merchant card processor relationships
 - c. Assigning new merchant IDs and equipment
 - d. Maintaining an inventory of all merchant IDs and processing equipment
 - e. Establishing users on bank systems and acting as security administrator on all merchant card reporting systems
 - f. Monitoring of credit card transaction volumes and fees
 - g. Periodically review credit card activity to detect fraud
 - h. Receiving and responding to general comments or concerns regarding PCI DSS and associated business practices
8. Annual education on PCI compliance is required for all Team Members involved in any business process or HIT function supporting those business processes related to credit card processing. Training will address:
 - a. PCI compliance
 - b. AAH's policies and procedures relating to handling of credit card and other regulated data
 - c. Accepting payment cards
 - d. Merchant account administration

- e. Consequences for failure to comply with the policy
 - f. Incident response plan
 - g. Security awareness
 - h. Vulnerability scanning and remediation
9. Any Team Member that becomes aware or suspicious of a payment card security event, incident, and/or breach must report it to the Advocate Aurora HIT Service Desk to start the process required by the Cybersecurity Incident Response Policy.
10. Governance of this policy is the responsibility of the PCI Steering Committee which is led by the Senior Vice President Treasury Services and comprised of representatives from HIT, Legal, Accounting/Finance and Merchant Account business owners.

V. PROCEDURE

Not Applicable

VI. CROSS REFERENCES

- A. AAH HIT Security and Risk Management
- B. AAH Enterprise Information Security & Chief Information Security Officer Standard
- C. AAH HIT Electronic Systems Account Management (ESAM)
- D. Electronic Systems Account Management (ESAM) Password Appendix A
- E. AAH HIT Electronic Systems Account Management (ESAM) Standard
- F. AAH Network Security
- G. AAH Vulnerability Management Standard
- H. AAH Record Retention, Storage and Destruction
- I. AAH Information Classification
- J. AAH Disposal of Protected Health Information or Other Restricted Information
- K. AAH Signature Authority and Contracting
- L. AAH Vendor Vetting
- M. AAH HIT Incident Notification and Incident Command Activation
- N. AAH Cybersecurity Incident Response
- O. AAH Business Continuity Plan
- P. AAH Health Informatics & Technology Disaster Recovery
- Q. HIT Data Backup and Recovery

VII. RESOURCES AND REFERENCES

For more information about this standard visit the official website at:
<https://www.pcisecuritystandards.org>.

VIII. ATTACHMENTS

A. Roles and Responsibilities (see below)

Roles and Responsibilities

Function	Responsibility
Team Members	Report any known or suspected breaches of payment card information to the Chief Privacy Officer.
Cybersecurity Incident Response Team (CSIRT)	Investigate and document the facts related to suspected or confirmed PCI DSS incidents. Customer cardholder data is considered personally identifiable information for the purpose of this policy.
Merchant Account Owner	Manager from the business team who is requesting a MID to process credit cards; business owner of processes around their instance of receiving credit card payments.
PCI DSS Steering Committee	Lead efforts that enable Advocate Aurora to be compliant with PCI DSS. Monitor internal and external information security requirements. Develop policies and guidance to support payment card security requirements. Remediate payment card breaches through coordination with the Chief Privacy Officer and the office of the CISO. Approve requests for new payment card programs or changes to existing payment card programs where such changes impact compliance with this policy.
Purchasing	Ensure that any third-party service provider selected to provide payment card services has been approved by the PCRB prior to initiating the contract process.
Legal	Review, negotiate and approve contracts with third-party service providers who deliver services subject to PCI DSS..
HIT	Implement this Policy relative to IT Infrastructure. Ensure that third-party service providers selected by HIT to provide payment card services are compliant with PCI DSS. Document and maintain a PCI Information Technology Standard, compliance framework, ongoing work plan, Data Flow Diagrams, and Architectural Context Diagrams.
Treasury	Obtain Merchant Account ID from the appropriate financial institution based on requests received from the PCRB. Maintain an active listing of all Merchant Account IDs within Advocate Aurora.